Care Access Navigator

CloudSec1 Rubric — Criterion 4: Identity & Access Management Implementation
Evidence Package — Keycloak ↔ Microsoft Entra ID Federation & RBAC Role Assignment

---

Prepared by:	Akhila Chennamaneni
Capstone:	Care Access Navigator (HealthLine Regional Medical Center)
Rubric criterion:	Criterion 4 — Identity & Access Management Implementation (CloudSec1)
Environment:	Keycloak 26.0 (Docker, realm: care-access-navigator) ↔ Microsoft Entra ID (Default Directory)
Evidence date:	September 30, 2026

Objective

Criterion 4 requires a direct cloud extension of the Keycloak identity provider and CAN's seven-role RBAC model, implemented as federation from Keycloak into the cloud provider's identity platform. This package documents the genuine, tested configuration of OpenID Connect (OIDC) federation between Keycloak (CAN's primary IdP) and Microsoft Entra ID, followed by automatic least-privilege role assignment for a federated identity.

Scope of this evidence package

- Entra ID app registration verification and client secret generation
- Redirect URI configuration linking Entra ID to the Keycloak broker endpoint
- Keycloak OIDC Identity Provider configuration (discovery endpoints, client credentials)
- End-to-end federated login test (Microsoft sign-in → Keycloak account console)
- Existing attribute mappers (email, first name, last name, username) confirmed
- RBAC role mapper (Hardcoded Role, Force sync) assigning the security-analyst CAN role on login
- A genuine configuration error encountered and resolved (documented below, not hidden)
- Final verification: role mapping confirmed on the federated user account

Federation Architecture

Keycloak (realm **care-access-navigator**) is configured with Microsoft Entra ID as an OpenID Connect Identity Provider, aliased **entra-id**. When a user authenticates through the entra-id button on Keycloak's login page, they are redirected to Microsoft's real sign-in flow. On successful authentication, Microsoft returns an ID token to Keycloak at the broker endpoint below, and Keycloak provisions/updates a local federated user record, applying attribute mappers (profile sync) and role mappers (RBAC assignment) automatically.

Component	Value
Keycloak realm	care-access-navigator
Identity Provider alias	entra-id
Entra ID app registration	care-access-navigator-keycloak-broker
Entra ID tenant	02de1b12-6fec-4370-b0fe-3c115598cdac
Redirect URI (broker endpoint)	http://localhost:8080/realms/care-access-navigator/broker/entra-id/endpoint
Authorization / Token / JWKS	https://login.microsoftonline.com/{tenant-id}/... (v2.0 OIDC endpoints)
Client authentication	Client secret sent as POST
Assigned CAN RBAC role	security-analyst
Sync mode override	Force (role re-asserted on every login)

Step-by-Step Implementation Evidence

STEP 1 Verify Entra ID App Registration & Generate Client Secret

The app registration **care-access-navigator-keycloak-broker** already existed with two prior client secrets, both masked and unverifiable. Rather than risk using a secret whose full value was never confirmed as saved, a fresh client secret was generated and copied immediately, since Entra ID reveals a secret's full value only once, at creation.

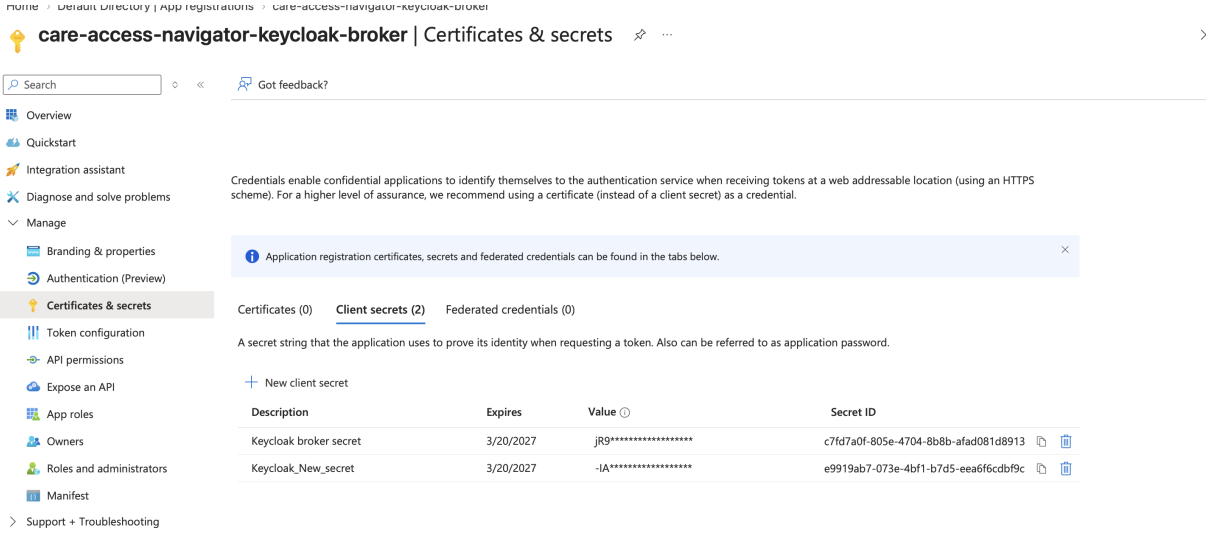


Figure 1. Entra ID app registration — Certificates & secrets page, client secret generated.

STEP 2 Configure the Redirect URI

The app registration's Authentication settings were configured with a Web platform redirect URI pointing to Keycloak's broker endpoint for the entra-id provider alias, ensuring Microsoft's authentication response is delivered back to the correct Keycloak callback.

> **Verification note:** the alias segment (entra-id) in this URL must match the Identity Provider alias configured in Keycloak exactly, or the federated login will fail to resolve.

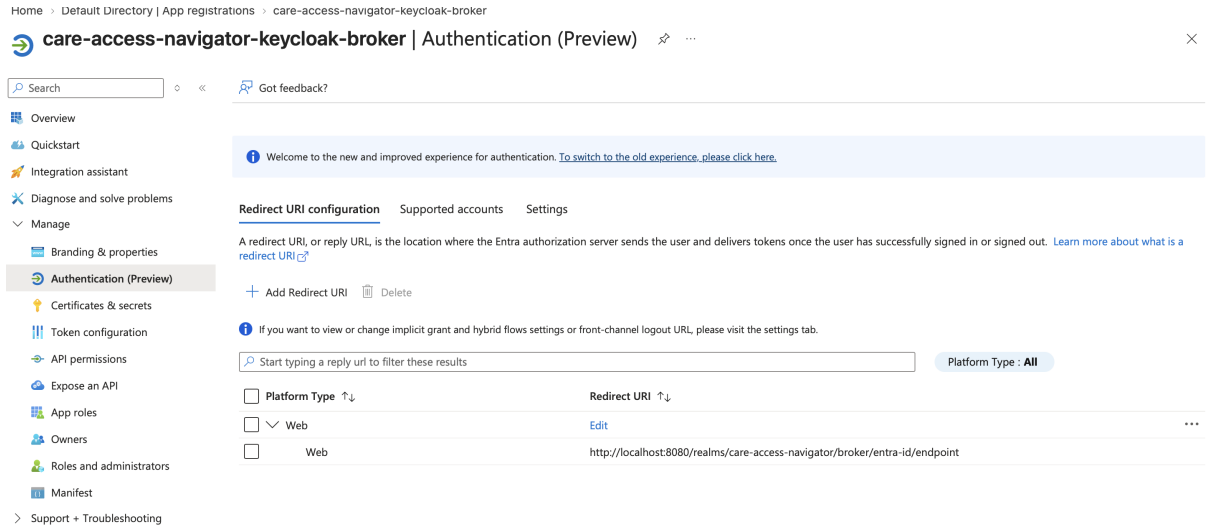


Figure 2. Entra ID app registration — Authentication page, redirect URI confirmed: http://localhost:8080/realms/care-access-navigator/broker/entra-id/endpoint

STEP 3 Configure the Keycloak OIDC Identity Provider

In the care-access-navigator realm, an OpenID Connect v1.0 Identity Provider was configured with alias **entra-id**. The discovery endpoint resolved Entra ID's Authorization URL, Token URL, Logout URL, User Info URL, Issuer, and JWKS URL automatically, confirming Keycloak could successfully reach Entra ID's OIDC metadata for this tenant.

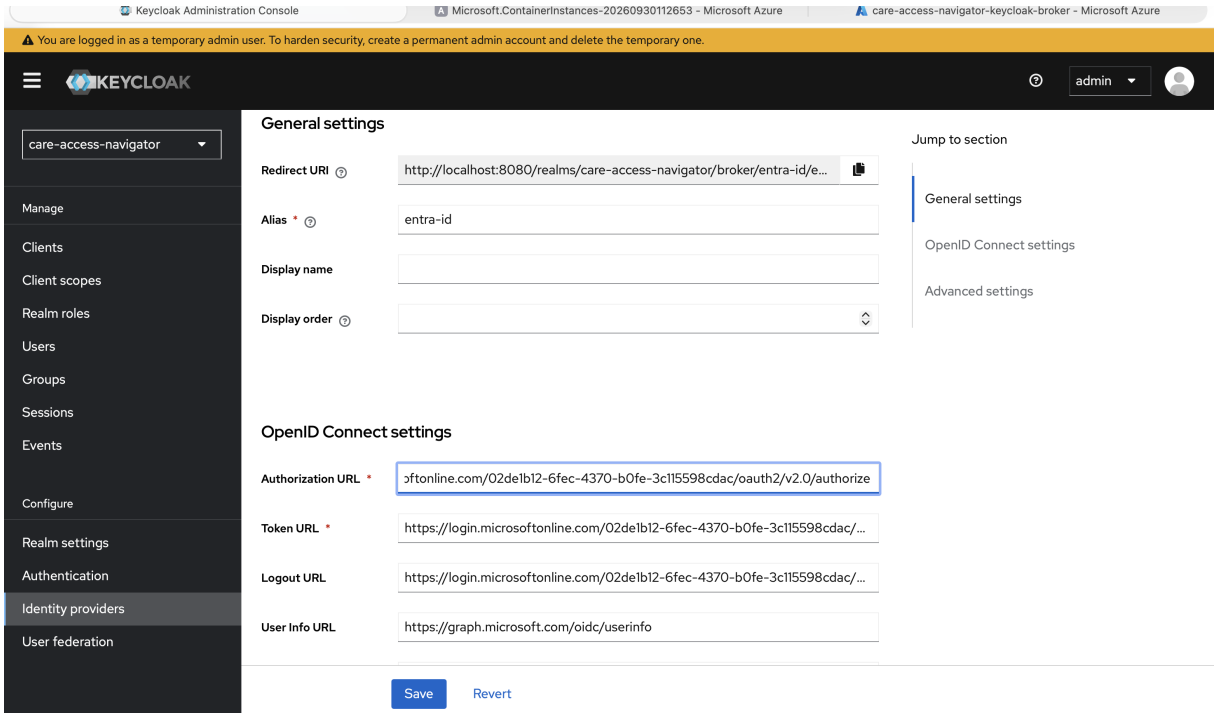


Figure 3. Keycloak Identity Provider — General settings and OpenID Connect settings, auto-resolved Entra ID endpoints for tenant 02de1b12-6fec-4370-b0fe-3c115598cdac.

STEP 3b Confirm Client Credentials in Keycloak

Scrolling further into the same provider configuration confirmed Client authentication was set to “Client secret sent as POST,” the Client ID matched the Entra ID app registration exactly, and the Client Secret field was refreshed with the newly generated secret from Step 1 to eliminate any ambiguity from the prior unverified secrets.

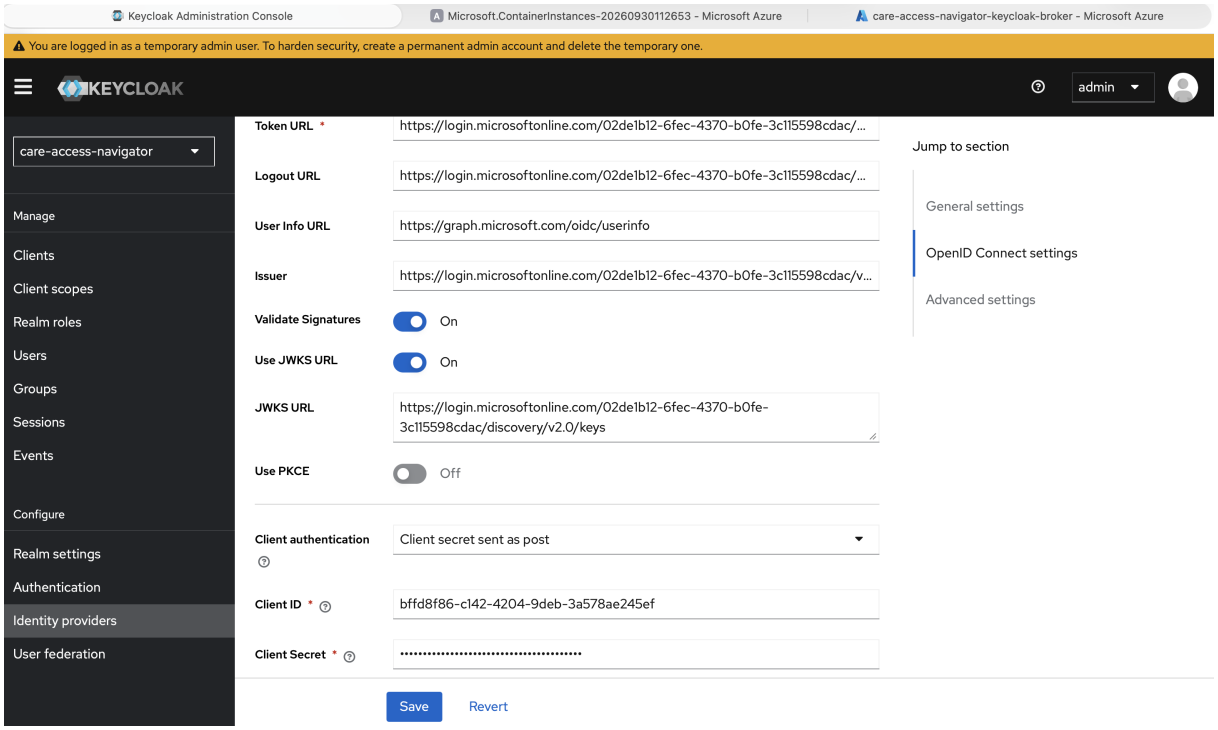


Figure 4. Keycloak Identity Provider — Client ID, Client Secret, and signature validation settings.

STEP 4 End-to-End Federated Login Test — Success

With configuration complete, the entra-id login button on the realm's account console was used to trigger a real authentication flow: Keycloak redirected to Microsoft's sign-in page, the user authenticated with a genuine Entra ID identity, and Microsoft redirected back to Keycloak. The resulting account console page confirms a successful login, with the user's profile (name, email) auto-populated from the federated identity token.

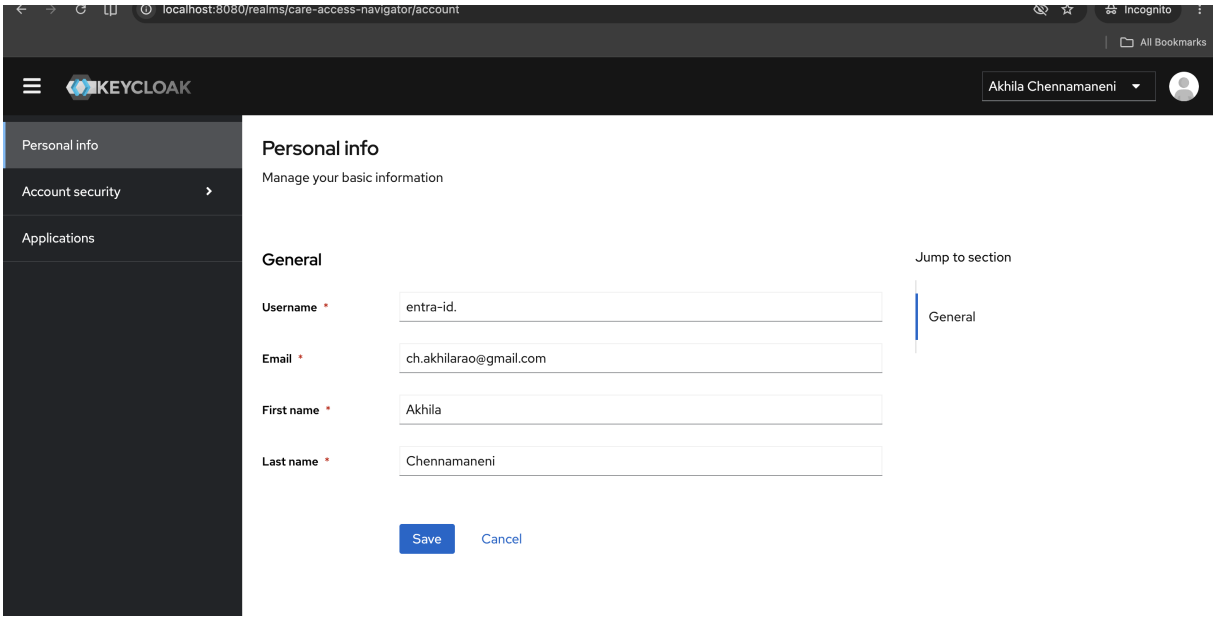


Figure 5. Keycloak account console, post-federation — logged in as Akhila Chennamaneni via entra-id, profile fields synced from the Entra ID token.

STEP 5 Confirm Existing Attribute Mappers

Before adding RBAC logic, the entra-id provider's existing Mappers were reviewed: a username-template mapper (preprocessor) plus three Attribute Importer mappers for email, first name, and last name. These explain the profile auto-population seen in Step 4 and confirm identity attribute sync was already correctly implemented.

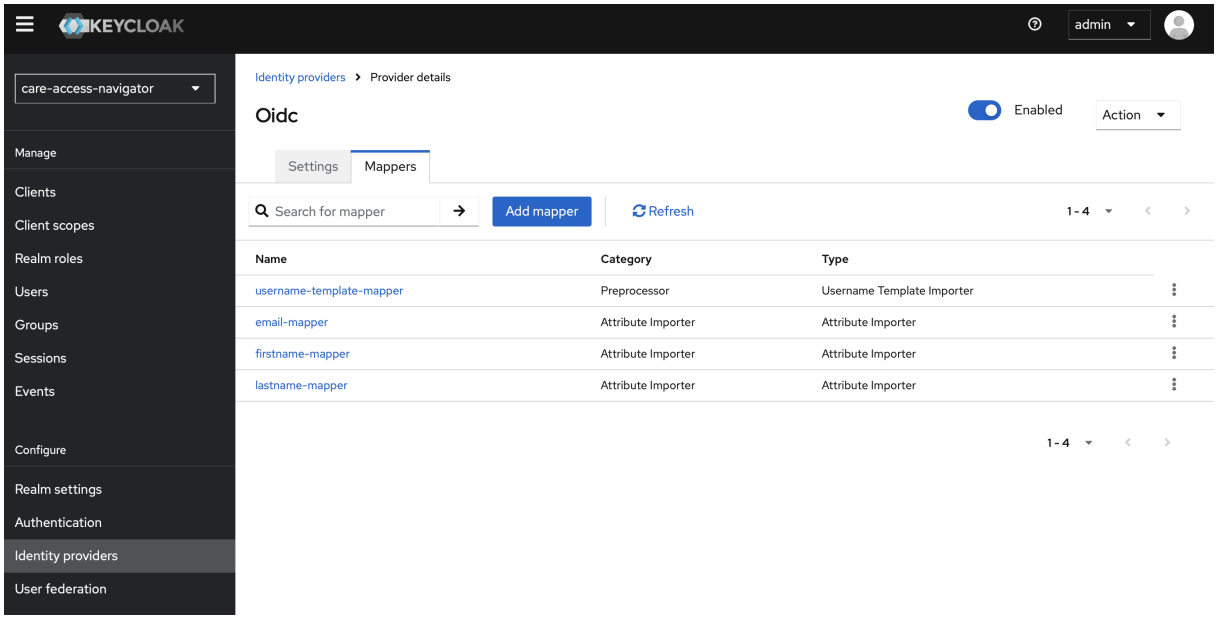


Figure 6. Keycloak Identity Provider Mappers tab — four existing attribute mappers (pre-RBAC-mapper state).

STEP 6 Add the RBAC Role Mapper — Troubleshooting a Real Configuration Error

A Hardcoded Role mapper was added with Sync Mode Override set to **Force**, so the assigned CAN role is re-asserted on every federated login rather than only at first account creation. The first attempt used the role name **Security-Analyst** and produced no visible role assignment after a fresh login. Checking the realm's actual Realm roles list revealed the true role name is lowercase and hyphenated: **security-analyst** — the mapper had silently failed to resolve a role name that did not exist as typed.

> **Root cause & fix:** role names in Keycloak's Hardcoded Role mapper must reference an existing realm role exactly. The mapper was recreated selecting security-analyst directly from the dropdown (rather than typed manually) to eliminate any further mismatch.

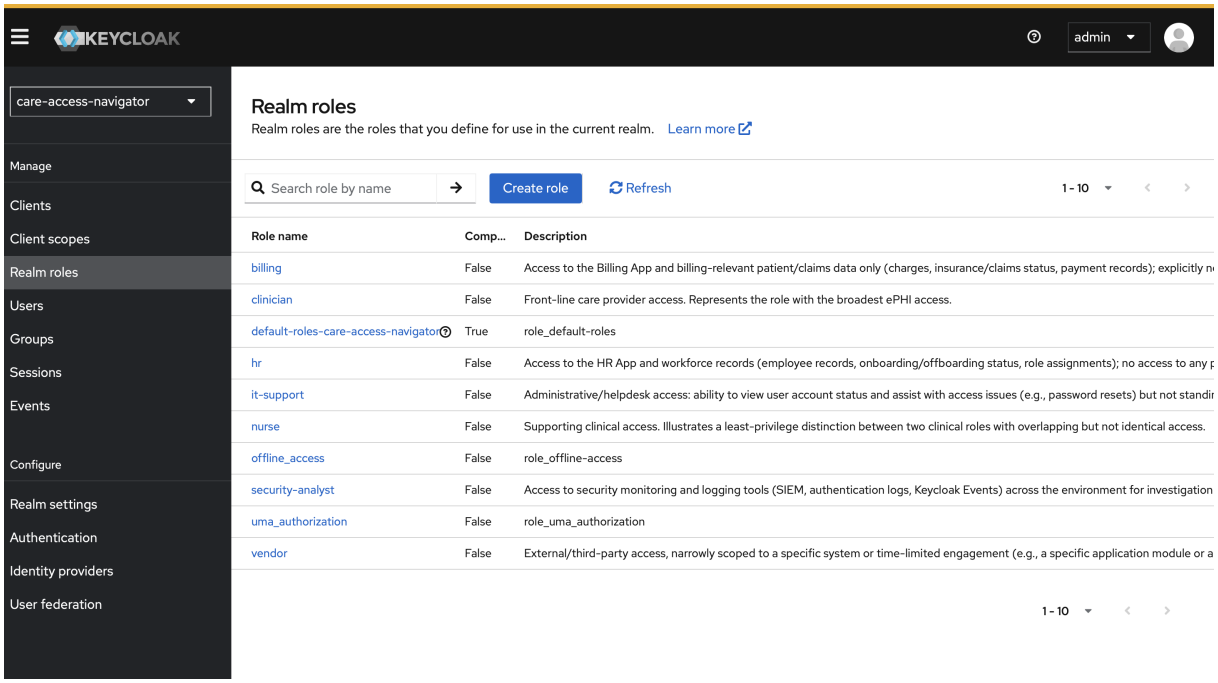


Figure 7. Keycloak Realm roles — confirms the seven CAN RBAC roles (billing, clinician, hr, it-support, nurse, security-analyst, vendor) and the exact casing required for the role mapper.

STEP 7 Re-Test Federated Login After the Fix

The account console session was signed out and a fresh federated login was performed in a private browsing window to force a new authentication event, since role mappers with Force sync only re-apply at the moment of login — not retroactively to an already-active session.

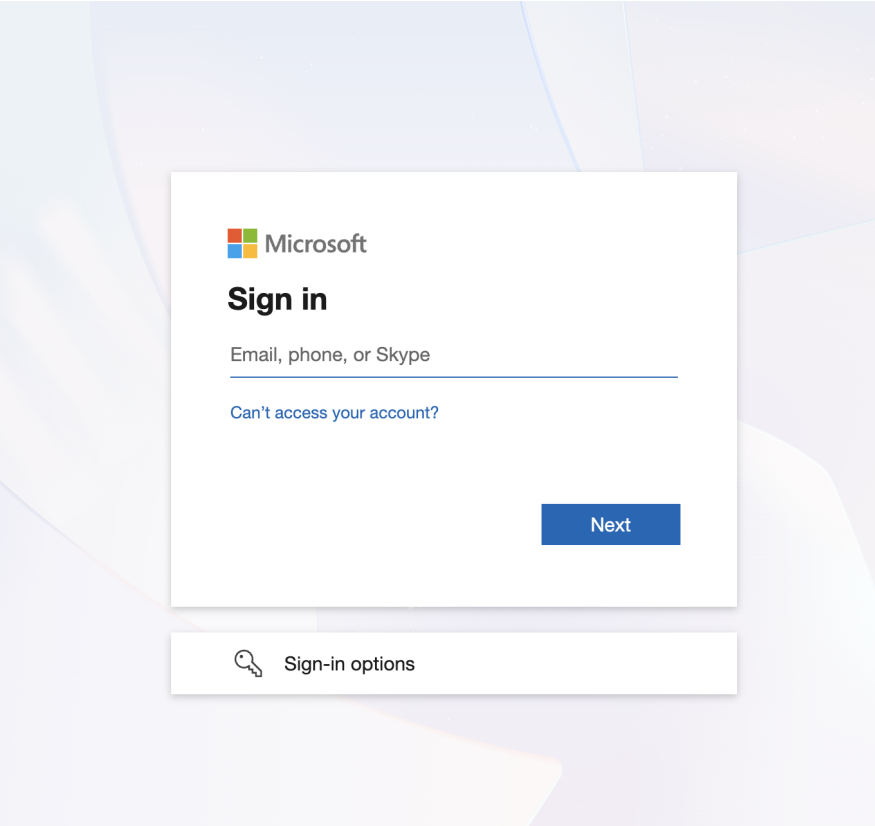


Figure 8. Microsoft sign-in page during the repeat federated login test.

STEP 7b Identify the Federated User Record

In the Keycloak admin console, the Users list confirms a single federated user record (username entra-id., email ch.akhilarao@gmail.com, name Akhila Chennamaneni) was created by the federation — distinct from the seven synthetic test.[role]01 accounts used elsewhere in CAN's native RBAC testing.

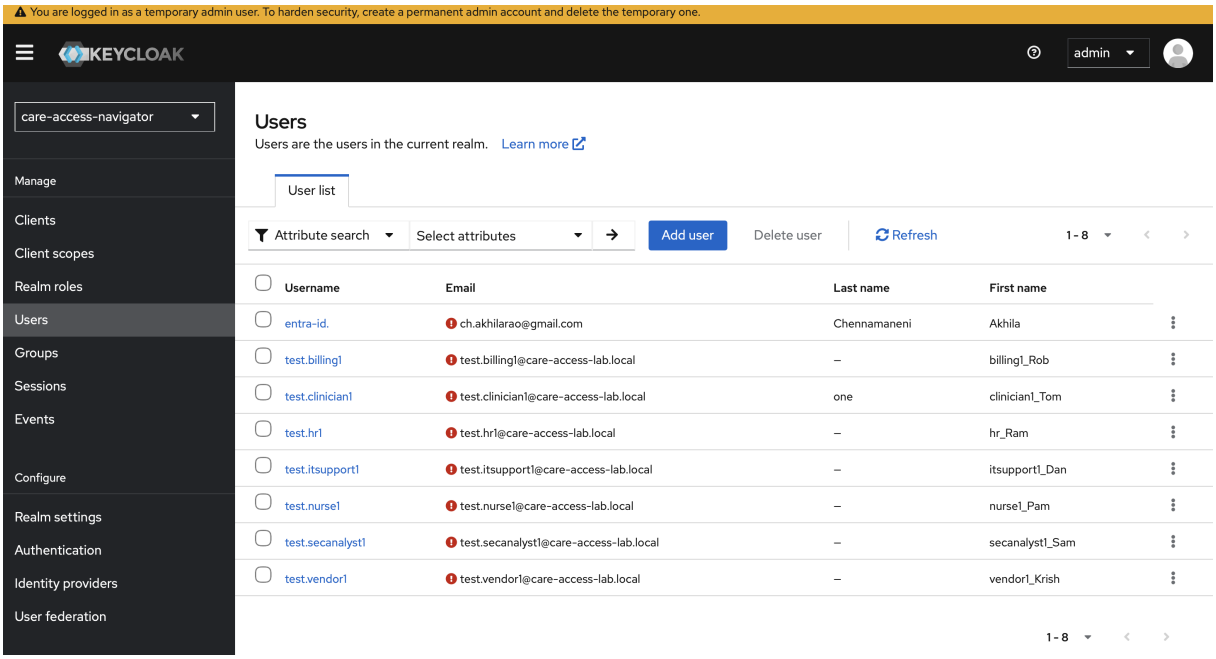


Figure 9. Keycloak Users list — the federated entra-id. account alongside CAN's existing synthetic test users.

STEP 8 Final Verification — Role Successfully Applied

Opening the federated user's Role mapping tab after the corrected mapper and repeat login confirms **security-analyst** is now assigned, alongside the realm's default role. This is the conclusive evidence that federated authentication and automatic least-privilege RBAC assignment are both functioning together as designed.

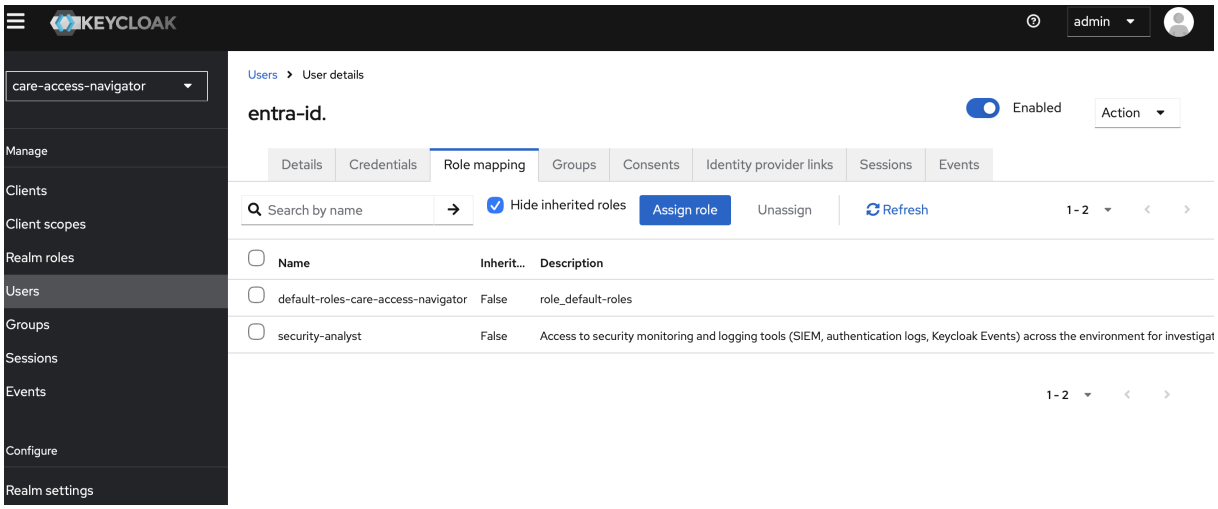


Figure 10. Keycloak Role mapping tab — security-analyst role confirmed on the federated user (FINAL EVIDENCE).

Compliance & Control Mapping

Control Area	HIPAA Security Rule	NIST CSF 2.0	CAN Evidence
Federated authentication	§164.312(d) Person/Entity Authentication	PR.AA-01 (Identity management)	Figures 3–5 (OIDC federation, successful login)
Automatic least-privilege role assignment	§164.308(a)(4) Information Access Management	PR.AA-05 (Access permissions managed)	Figures 6–10 (role mapper, verified assignment)
Credential management	§164.312(a)(2)(i) Unique User Identification	PR.AA-01	Figure 1 (client secret lifecycle, stale-secret avoid

Implementation Status

Implemented & verified: OIDC federation (Keycloak ↔ Entra ID), profile attribute sync, automatic RBAC role assignment via Hardcoded Role mapper (Force sync) for a single federated identity.

Known limitation (by design, for this pass): The current role mapper applies **security-analyst** to any user authenticating through this Entra ID provider. It does not yet differentiate federated users into different CAN roles.

Planned enhancement: Replace the Hardcoded Role mapper with an Attribute Importer mapper driven by real Entra ID group claims, so different federated identities map to different CAN roles (Clinician, Nurse, Billing, HR, IT-Support, Security-Analyst, Vendor). This requires configuring groupMembershipClaims on the app registration manifest and assigning test identities to distinct Entra ID groups — out of scope for today's build due to the Azure credit expiration window.

> This evidence was captured on 2026-09-30, the final day of the Azure subscription credit window. Steps requiring live Entra ID portal access (Steps 1–2) were completed first; Keycloak-side configuration and testing (Steps 3–8) do not depend on continued Azure billing, since Keycloak runs locally via Docker.

Addendum — Role-Differentiated Federation

Update of October 6, 2026: the planned enhancement on page 11 is now implemented and verified

This addendum supersedes the "Known limitation" and "Planned enhancement" in the Implementation Status on page 11. Pages 1–11 are preserved unchanged as the record of the September 30 build.

Summary

On September 30, every user who signed in through Entra ID received the **security-analyst** role from a Hardcoded Role mapper, regardless of who they were. On October 6 this was replaced with **role-differentiated federation**: each person's CAN role is now assigned in Entra ID and carried to Keycloak in the token's `roles` claim, where it is mapped to the matching Keycloak realm role. Two new Entra ID test identities — a Billing user and a Nurse user — signed in end-to-end and each received **only** their own role.

	September 30 (pages 1–11)	October 6 (this addendum)
How the CAN role is decided	Hardcoded: everyone gets security-analyst	Per user, from the Entra ID app role assigned to them
Billing user receives	security-analyst (wrong)	**billing** only
Nurse user receives	security-analyst (wrong)	**nurse** only
Who can sign in	Assigned users	Assigned users only (assignment required = true)
Federated username	`entra-id.` (claim missing)	`entra-id.<UPN>`, unique per person

Approach: App Roles instead of Group Claims

Page 11 planned to use Entra ID *group* claims. Assigning groups to an enterprise application requires a Microsoft Entra ID P1/P2 licence, and this tenant is on the Free tier (no subscribed SKUs). **App roles** achieve the same result on the Free tier: the seven CAN roles are defined on the app registration, a role is assigned to each user on the enterprise application, and Entra ID emits it in the `roles` claim of the ID token. This is also the more direct model — the role is attached to the person's access to this specific application, not inferred from general directory groups.

Issues Found During the Audit

Before adding the new users, the existing federation was audited from both sides (Entra ID and Keycloak). Three defects were found in the September 30 configuration:

#	Defect	Impact	Fix
1	Two Hardcoded Role mappers (`role-mapper`, `security-analyst`) granted security-analyst to every Entra ID login	**Least-privilege violation** — a nurse or billing clerk would receive security-analyst access	Both mappers deleted (backed up first)
2	No Claim-to-Role mappers read the Entra ID `roles` claim	Roles assigned in Entra ID were silently ignored	Seven Claim-to-Role mappers added, one per CAN role
3	Keycloak requested only the `openid` scope, so `preferred_username`/`email` were absent	Username template produced `entra-id.` for everyone — all federated people would collapse into one Keycloak account	Scopes set to `openid profile email`; the broken account was deleted

> **Note on pages 9–10:** The federated account shown in Figures 9–10 (username `entra-id.`) was a symptom of defect 3. It was exported to a backup and deleted; the administrator's next sign-in created a correctly named account, `entra-id.ch.akhilarao@gmail.com`.

STEP 9 Assign CAN roles in Entra ID

The app registration **care-access-navigator-keycloak-broker** defines the seven CAN app roles (Billing, Clinician, HR, IT-Support, Nurse, Security-Analyst, Vendor). Two test identities were created and each was assigned exactly one role on the enterprise application. **Assignment required** is enabled, so a user with no assignment cannot sign in at all.

Entra ID enterprise application — role assignments (Microsoft Graph)

```
== Entra ID: app role assignments on care-access-navigator-keycloak-broker ==
Akhila Chennamaneni    -> Default Access
Test Nurse             -> Nurse
Test Billing           -> Billing
assignment required: true
```

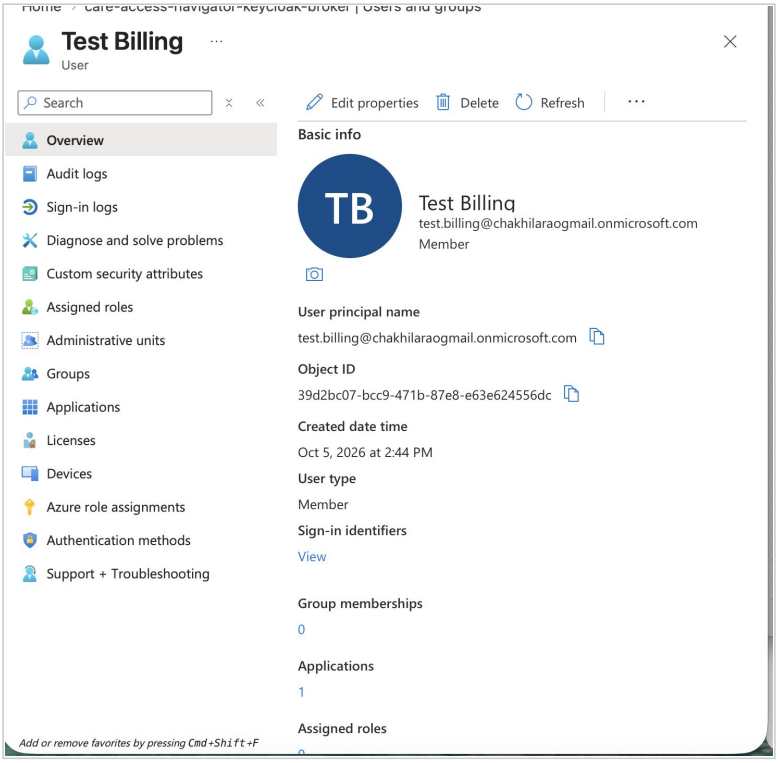


Figure 11. Entra ID user Test Billing (test.billing@chakhilaraogmail.onmicrosoft.com) — member account assigned to the broker application.

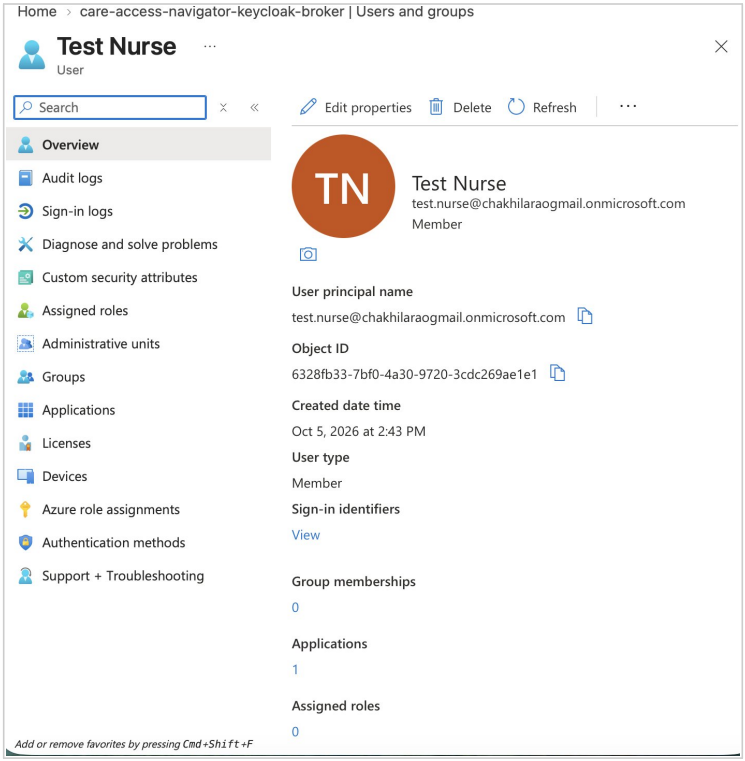


Figure 12. Entra ID user Test Nurse (test.nurse@chakhilaraogmail.onmicrosoft.com) — member account assigned to the broker application.

STEP 10 Map the Entra ID roles claim to Keycloak realm roles

On the **entra-id** identity provider, seven **Claim to Role** mappers translate each value of the `roles` claim into the matching realm role. All use sync mode **Force**, so a role change in Entra ID takes effect at the user's next sign-in, and removing a role in Entra ID removes it in Keycloak. The provider now requests `openid profile email` and sends `prompt=select_account`, so Microsoft always asks which account to use instead of silently reusing the administrator's session.

Keycloak — entra-id identity provider configuration

```
== Keycloak: entra-id identity provider mappers (all sync mode FORCE) ==
email-mapper                 claim email -> email
entra-role-billing           roles claim = Billing -> realm role billing
entra-role-clinician         roles claim = Clinician -> realm role clinician
entra-role-hr                roles claim = HR -> realm role hr
entra-role-it-support        roles claim = IT-Support -> realm role it-support
entra-role-nurse             roles claim = Nurse -> realm role nurse
entra-role-security-analyst  roles claim = Security-Analyst -> realm role security-analyst
entra-role-vendor            roles claim = Vendor -> realm role vendor
firstname-mapper             claim given_name -> firstName
lastname-mapper              claim family_name -> lastName
username-template-mapper     template ${ALIAS}.${CLAIM.preferred_username}

== Keycloak: entra-id provider settings ==
defaultScope = openid profile email
prompt       = select_account
```

STEP 11 End-to-end verification

Each test user signed in through the **entra-id** button in a private browser window, set a new password at Microsoft's first-sign-in prompt, and was returned to Keycloak. Keycloak's event log recorded `IDENTITY_PROVIDER_FIRST_LOGIN` → `REGISTER` → `LOGIN` for `entra-id.test.billing@…` (13:30 EDT) and `entra-id.test.nurse@…` (13:36 EDT) with no errors. The resulting accounts hold only their own role:

Keycloak — federated users and their realm roles

```
== Keycloak: federated (entra-id) users and realm roles ==
entra-id.ch.akhilarao@gmail.com                          (none)
entra-id.test.billing@chakhilaraogmail.onmicrosoft.com  billing
entra-id.test.nurse@chakhilaraogmail.onmicrosoft.com    nurse
```

Test	Expected	Result
Billing user signs in via Entra ID	Keycloak role billing only	**PASS** — billing
Nurse user signs in via Entra ID	Keycloak role nurse only	**PASS** — nurse
Either user receives security-analyst	No	**PASS** — not assigned
Administrator (Default Access, no CAN role)	No CAN role	**PASS** — none
billing-app role scope (config; fullScopeAllowed = false)	billing	**PASS** — billing
ehr-simulator / patient-portal role scope (config)	nurse, clinician	**PASS** — nurse, clinician

Also corrected: Keycloak's seven local test accounts (test.billing1 … test.vendor1) had no realm roles assigned. Each was given the role matching its name, so local and federated test identities now behave the same.

Updated Implementation Status

Implemented & verified: OIDC federation (Keycloak ↔ Entra ID); profile attribute sync; **role-differentiated** RBAC — each federated identity receives exactly the CAN role assigned to it in Entra ID, for all seven roles, with Force sync; enterprise application assignment required; account picker enforced at sign-in.

Control area	HIPAA Security Rule	NIST CSF 2.0	Addendum evidence
Role-based least privilege	§164.308(a)(4) Information access management	PR.AA-05 (access permissions managed)	Steps 9–11, Fig. 11, 12
Unique user identification	§164.312(a)(2)(i) Unique user identification	PR.AA-01 (identities managed)	Defect 3 fix; per-person usernames
Access review / correction	§164.308(a)(1)(ii)(D) Information system activity review	ID.IM-02 (improvements identified)	Issues found during the audit